

**UNIVERSIDAD COMPLUTENSE
DE
MADRID**

MASTER EN CIBERSEGURIDAD



ALUMNO: Darwin Marcani Rojas

PROFESOR: D. Igor Lukic Nikolic

España-Madrid

2026

Contenido

1. Conocimientos aplicados a la Ingeniería Social	4
1.2. Phishing	4
1.3. Tarea Concienciación	7
1.4. Tarea Deepfake	9
1.5. Tarea Ingeniería Social	9

Contenido de tablas

Tabla 1.	Storyline	4
-----------------	-----------------	---

Contenido de figuras

No se encontraron entradas de tabla de contenido.

1. Conocimientos aplicados a la Ingeniería Social

1.2. Phishing

Guion/Storyline:

Storyline — Campana Phishing Hospital General ACME

Elemento	Decisión	Justificación
Remitente	Departamento de TI interno	Es el único emisor legítimo de ejecutables; el personal no cuestiona sus instrucciones
Pretexto	Actualización de seguridad + renovación de licencia anual del HIS	Combina urgencia técnica con rutina administrativa; no levanta sospechas
Acción pedida	Ejecutar adjunto en 3 pasos simples	Mínima fricción = máximo alcance en campaña masiva
Urgencia	Fecha límite + bloqueo de acceso a historiales clínicos	Presión institucional y profesional; afecta directamente la atención al paciente
Público objetivo	Todo el personal del hospital	Médicos, enfermería, administrativos — todos usan el HIS

Tabla 1. Storyline

Ejemplo correo electrónico:

De: soporte.ti@hospitalgeneralacme.com

Para: [personal]@hospitalgeneralacme.com

Asunto: Acción requerida: actualización obligatoria HIS – fecha límite 30/05/2026

Estimado/a compañero/a,

El Departamento de TI informa que el sistema HIS requiere una actualización crítica de seguridad y renovación de licencia anual antes del cierre del mes.

Los equipos que no completen el proceso quedarán bloqueados automáticamente a partir del 30/05/2026. El incumplimiento será notificado al responsable directo del área correspondiente.

Para completar la actualización:

1. Descargue el archivo adjunto: HIS_Actualizacion_v3.2.exe
2. Ejecútelo y siga los pasos del instalador
3. Al finalizar, el sistema se actualizará automáticamente

Recuerde: tiene hasta el 30/05/2026 para completar este proceso.

Departamento de Tecnología e Informática

Hospital General ACME

Ext. interna: 1042

soporte.ti@hospitalgeneralacme.com

Explicación de las razones por la que la campaña es indicada para cualquier tipo de usuario:

Razones por las que la campaña es efectiva para cualquier tipo de usuario:

1. **Bajo conocimiento técnico:** la mayoría del personal no distingue un ejecutable legítimo de uno malicioso, independientemente de su rol.
2. **Atención centrada en el paciente:** el personal sanitario tiene la atención dividida, resuelven el correo rápido sin analizarlo para volver a su trabajo.
3. **Miedo laboral:** el bloqueo de acceso al sistema y la notificación al responsable directo afecta al bolsillo y la estabilidad laboral de cualquier empleado.
4. **Presión de fecha límite:** genera urgencia inmediata y ansiedad de tarea pendiente, llevando al usuario a ejecutar sin pensar.
5. **Autoridad del remitente:** el dominio legítimo del hospital, el tono institucional y la palabra "obligatoria" eliminan cualquier duda sobre la legitimidad del correo.

1.3. Tarea Concienciación

- Lista de acciones para implementar en nuestros procesos:

Procedimientos para frenar implantes Wifi y pendrives sospechosos:

1. Control de acceso físico

- Verificar identidad y permisos de toda persona que ingrese a zonas restringidas
- Confirmar quién autorizó la visita antes de permitir el acceso
- Prohibición de celulares en zonas de trabajo
- Clientes atendidos individualmente, sin acompañantes

2. Supervisión física

- Acompañamiento obligatorio de personal de seguridad en zonas restringidas
- Ningún externo puede permanecer sin escolta en áreas de trabajo

3. Vigilancia

- Cámaras de seguridad apuntando a zonas de trabajo y equipos
- Revisión periódica de grabaciones ante incidentes

4. Hardening de endpoints

- Bloqueo de puertos USB por política de grupo (GPO)
- Uso de pendrives únicamente si está autorizado y supervisado
- Cortafuegos perimetral activo y actualizado

5. Segmentación de red

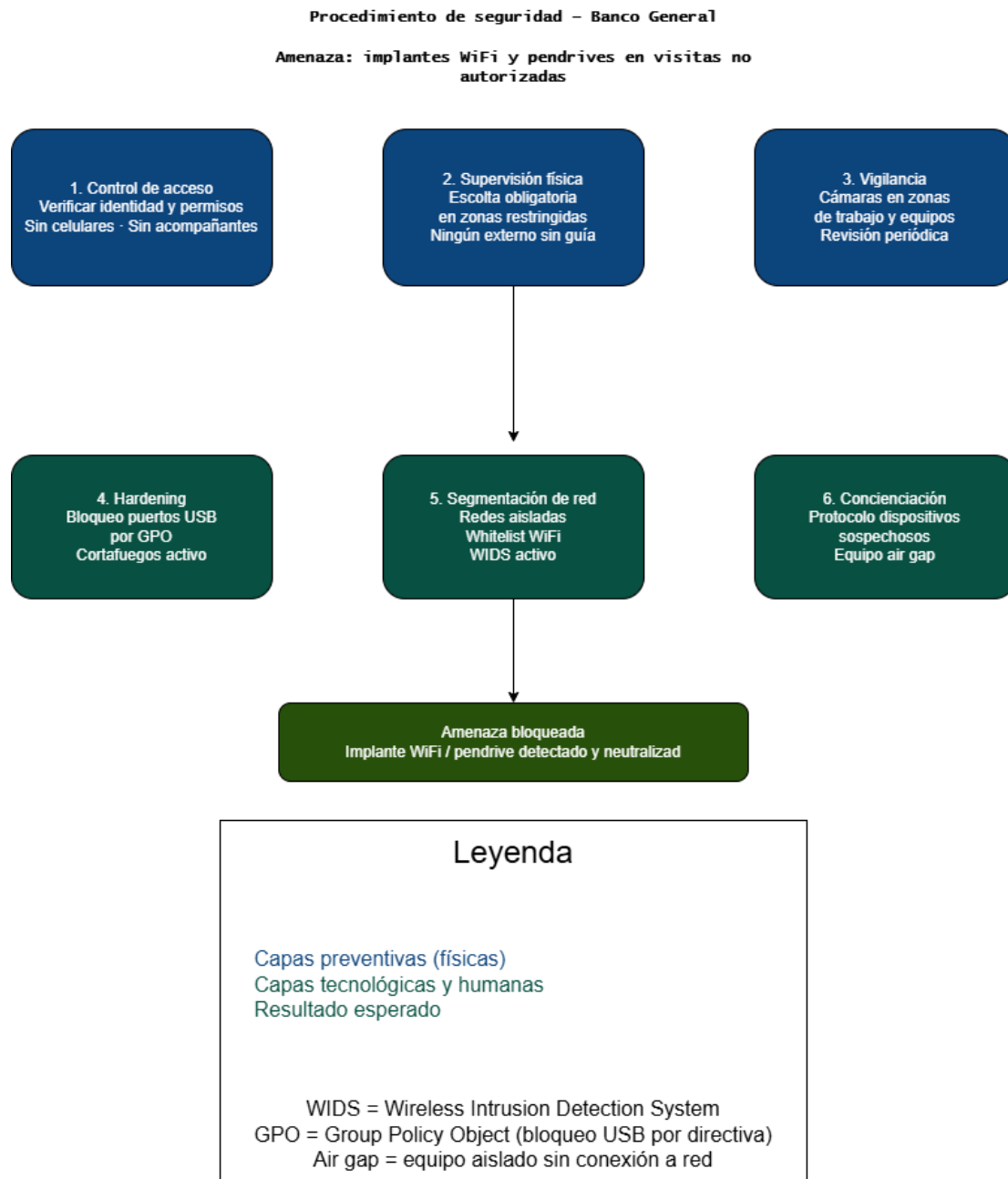
- Redes segmentadas — ninguna zona crítica conectada a la red general
- Whitelist de redes WiFi autorizadas por dispositivo
- Sistema WIDS (Wireless Intrusion Detection System) para detectar puntos de acceso no autorizados

6. Concienciación del personal

- Protocolo claro ante dispositivos encontrados — no tocar, reportar a seguridad inmediatamente
- Prohibición de aceptar pendrives de externos bajo ningún concepto

- Dispositivos sospechosos analizados en equipo aislado (air gap) sin conexión a la red

Esquema básico visual o sketch



1.4. Tarea Deepfake

Imagen en él .zip

1.5. Tarea Ingeniería Social

Orden de más a menos efectivo para robar contraseña a recepcionista de hotel según lógica mía:

1. Phishing
2. Vishing
3. Deepfake IA
4. Inspección visual
5. Insertar dispositivo USB